AEGIS / Security Cloud

AUTHORIZED CONFIGURATION ASSESSMENT

Example organization

http://fixture.test

Assessment: 7970a35d-114b-48d4-bf18-f71863828f99

UTC: 2026-10-28T12:47:41.830223+00:00

Scope & methodology

Bounded GET requests to the exact authorized origin and explicitly listed paths: /. Response configuration and TLS inspection only. No redirects followed or automatic crawling.

Result: completed

Executive summary

6 configuration observations require review.

Configuration gaps can weaken browser-side defenses. Actual business impact and exploitability depend on the application and require human review.

Severity	Observations
Critical	0
High	0
Medium	3
Low	3

Executed profile: root-response-configuration-v3

Executed checks: cookie.httponly, cookie.secure, header.csp, header.frame, header.nosniff, transport.http

Not performed: header.hsts - HTTPS was not in this authorized origin.

Not performed: hsts.short - HTTPS was not in this authorized origin.

Not performed: tls.expiry - HTTPS was not in this authorized origin.

Not performed: csp.inline - CSP is absent; previous script policy cannot be validated.

Technical observations

Unencrypted HTTP response

Severity: medium | Confidence: high | Rule: transport.http

Evidence: The explicitly authorized origin used HTTP.

Recommended action: Serve this endpoint over HTTPS and plan a separately scoped redirect check.

Classification: observed configuration signal; exploitability is not established. Severity is qualitative, not a CVSS score.

Content Security Policy not observed

Severity: medium | Confidence: high | Rule: header.csp

Evidence: Content-Security-Policy was absent on this response.

Recommended action: Develop a restrictive CSP in report-only mode, validate it, then enforce it.

Classification: observed configuration signal; exploitability is not established. Severity is qualitative, not a CVSS score.

MIME-sniffing protection not observed

Severity: low | Confidence: high | Rule: header.nosniff

Evidence: X-Content-Type-Options: nosniff was not observed.

Recommended action: Set X-Content-Type-Options: nosniff.

Classification: observed configuration signal; exploitability is not established. Severity is qualitative, not a CVSS score.

Frame embedding restriction not observed

Severity: low | Confidence: high | Rule: header.frame

Evidence: Neither a non-wildcard frame-ancestors directive nor a recognized X-Frame-Options restriction was observed.

Recommended action: Set a suitable CSP frame-ancestors directive or X-Frame-Options.

Classification: observed configuration signal; exploitability is not established. Severity is qualitative, not a CVSS score.

A response cookie lacks Secure

Severity: medium | Confidence: high | Rule: cookie.secure

Evidence: At least one Set-Cookie header lacked Secure. Cookie names and values are intentionally omitted.

Recommended action: Apply Secure to security-sensitive cookies after HTTPS validation.

Classification: observed configuration signal; exploitability is not established. Severity is qualitative, not a CVSS score.

A response cookie lacks HttpOnly

Severity: low | Confidence: high | Rule: cookie.httponly

Evidence: At least one Set-Cookie header lacked HttpOnly. Cookie purpose requires human review.

Recommended action: Apply HttpOnly to session cookies that do not need JavaScript access. Human review must determine purpose.

Classification: observed configuration signal; exploitability is not established. Severity is qualitative, not a CVSS score.

Limitations & retesting

Explicitly authorized response paths only. No authenticated paths, application logic testing, exploitation or comprehensive penetration testing.

Validate each approved change and run a new authorized assessment. Absence in this response is not proof of global resolution. This report does not certify the website as secure.